Response to Reviewer 1

Enhancing Consent Policy Privacy in Blockchain-Based Healthcare Data Sharing

---

Working draft. The response text is complete for Comment 1. Page and line references will be added after the revised manuscript reaches final pagination.

Comments 1: *The security implications of the unbound program length should be more strongly addressed. According to the manuscript, the preimage of the commitment does not include the length of the program ℓ. Thus, a TPS that deviates from the prescribed workflow may consider a stack-consistent prefix of the committed token array instead of the full desired policy. This is not an implementation detail, but a matter of soundness. The proposed framework is oriented toward verifiable consent enforcement and therefore the authors should either bind the program length in the commitment/proof relation in the current implementation or give a much stronger justification for postponing this modification.*

Response 1: We thank the reviewer for identifying this soundness issue. We agree and have bound the program length in the commitment and proof relation in the current implementation.

In the submitted construction, the program length ℓ was used by the interpreter but was not bound to the policy commitment. A deviating TPS that knew the commitment opening could therefore attempt to evaluate a stack-consistent prefix under the commitment to the full padded token array. This can reverse an authorization outcome: for a requester satisfying A, the committed RPN program $[A, \mathrm{NOT}]$ with $\ell = 2$ denies, whereas the prefix $[A]$ with $\ell = 1$ grants.

The revised construction is

$$q = H_{\mathrm{pol}}(P_{\mathrm{enc}}),$$
$$h = \mathsf{Com}(P_{\mathrm{enc}}, \ell; r) = \mathsf{Poseidon}(q \parallel \ell \parallel r),$$

where H_{pol} is the circuit's fixed-length Poseidon aggregation. The same private `numOperations` value is supplied to both the commitment verifier and the RPN interpreter. Consequently, evaluating a different prefix would require opening h to a different (P_{enc}, ℓ) pair, which is excluded by the commitment's binding property under the collision resistance of Poseidon. The length remains private, and this modification adds no public proof input.

We added a dedicated regression suite that checks the following properties:

(i) the same padded token array and randomizer produce different commitments for different lengths;

(ii) a missing or out-of-range length is rejected;

(iii) the honest $[A, \mathrm{NOT}]$ program denies when $A = 1$;

(iv) its prefix authorizes when separately committed at length one, providing a positive control; and

(v) the truncated length cannot authorize under the commitment to the full program.

All seven regression tests pass. We also verified the frozen RC1 release manifest and cryptographic artifacts. The manifest records the production commitment as `Poseidon3(policyHash,`

`programLength, randomizer)` with `programLengthBound: true`. These RC1 artifacts were used for the of-record experiments, so the commitments and reported measurements were regenerated under the corrected relation.

The isolated circuit change adds 21 non-linear and 67 linear constraints, or 88 constraints in total (approximately 0.12% relative to the submitted 75,097-constraint circuit), and adds no public input. Thus, binding ℓ neither reveals the program length nor changes the policy-independent verification interface. Other independent revisions change the absolute circuit size and public-signal layout of the final revised system; the figures above isolate only the effect of program-length binding. Existing commitments and proving/verification keys from the submitted relation are incompatible with the revised relation and were regenerated.

Changes in the manuscript. The construction is now defined directly in the Design section, its integrity implication is distinguished from the metadata-privacy evaluation in the Discussion, and the former statement that program-length binding remained future work has been removed from the Conclusion.

Location in the revised manuscript: Section "TPS-ZKPI Design," subsection "Commitment Binding and Proof Generation."

> The semantics of an encoded policy are determined by the pair (P_{enc}, ℓ), since ℓ identifies the active prefix of the padded token array. Accordingly, the circuit supplies the same private value ℓ to both the commitment verifier and the policy interpreter. Under the collision resistance of Poseidon, an accepting proof bound to h cannot substitute a different program length and therefore cannot evaluate an alternative stack-consistent prefix of P_{enc}.

Location in the revised manuscript: Section "Discussion."

> As described in the Design section, the policy commitment covers both the padded encoding P_{enc} and its active length ℓ. Because ℓ also determines how many tokens the interpreter evaluates, an authorizing proof for h cannot be based on a shorter valid prefix. This integrity guarantee is separate from our privacy evaluation, which measures whether public-chain artifacts reveal information about the hidden policy.